Studio Nx

백엔드 150 — hash_reset_token()

2026-10-14

백엔드 150 — `hash_reset_token()` (재설정 토큰의 해시)

항목	내용
파일	`studionx/backend/app/core/security.py`
작업	P1-28 비밀번호 찾기 (FR-118): 첫 번째 함수
작성	Claude (AI), 2026-10-14, 사용자 검토
함께 만든 것	모델 `PasswordResetToken`(`app/models/password_reset_token.py`), `User.password_changed_at` 컬럼, 로컬 DB에 migration `2026-10-14_password_reset.sql` 실행
시험	`tests/test_reset_token_hash.py` 12개
다음	토큰 만들기(`generate_reset_token`), 요청 서비스, 새 비밀번호 서비스, 이전 로그인 무효화, 횟수 제한, 라우터 순서로 한 함수씩 진행합니다

1. 하는 일

재설정 링크에 들어가는 토큰 원문을 DB에 저장할 **해시**로 바꿉니다. 원문은 메일 링크에만 있고 DB에는 해시만 있습니다.

입력	결과
`"abc"`	`ba7816bf…0015ad` (소문자 16진수 64자)
같은 문자열을 두 번	항상 같은 값
빈 문자열, `None`, 숫자, `bytes`, 리스트	`ValueError`

2. 코드

```
def hash_reset_token(token: str) -> str:
    if not isinstance(token, str) or token == "":
        raise ValueError("token must be a non-empty string")
    return hashlib.sha256(token.encode("utf-8")).hexdigest()
```

3. 왜 이렇게

선택	이유
bcrypt가 아니라 SHA-256	비밀번호는 사람이 정한 약한 값이라 느린 해시(bcrypt)로 무차별 대입을 늦춰야 합니다. 토큰은 `secrets`로 만든 긴 무작위 값이라 무차별 대입이 불가능하고, 대신 링크를 눌렀을 때 **해시로 행을 바로 찾아야** 합니다. bcrypt는 같은 입력도 매번 다른 값(솔트)이 나와서 찾을 수 없습니다
원문을 저장하지 않음	DB가 유출되어도 해시만으로는 재설정 링크를 만들 수 없습니다
잘못된 값은 `ValueError`	빈 값이나 `bytes`가 조용히 해시되어 저장되는 일을 막습니다. 이 해시는 `token_hash` 유일 색인의 키입니다

4. 함께 한 준비

- **모델** `PasswordResetToken`: `password_reset_tokens` 테이블과 같은 열(`token_hash` 유일, `expires_at`, `used_at`)이고, 회원이 지워지면 함께 지워집니다(`ON DELETE CASCADE`).
- `User.password_changed_at`: 비밀번호를 재설정한 시각입니다. 이 시각보다 먼저 발급된 로그인을 무효로 만드는 데 씁니다(뒤 함수).
- **로컬 DB**: migration을 실행했습니다(이미 들어간 데이터는 그대로이고 열과 테이블만 추가).

5. 시험 (12개 통과)

확인	결과
표준 시험값(`abc`의 SHA-256)	✓
64자 소문자 16진수(`CHAR(64)`에 맞음)	✓
같은 입력은 같은 값, 다른 입력은 다른 값, 대소문자 구분	✓
해시에 원문이 들어 있지 않음	✓
한글은 UTF-8로 해시	✓
빈 문자열, `None`, 숫자, `bytes`, 리스트는 `ValueError`	✓

전체 pytest 696개 통과, `ruff` 통과.